Cybersecurity Fundamentals

Core security concepts, practical examples, and revision exercises

Personal study and revision reference

Contents

Security Fundamentals 3

Networking Basics for Security 5

Threats, Vulnerabilities, and Risk 6

Risk Management 8

Security Controls 9

Incident Response 10

Final Revision Checklist 12

Security Fundamentals

Purpose of cybersecurity

Cybersecurity protects systems, networks, people, and information from unauthorized access, disruption, alteration, or destruction. A security decision should preserve business services while reducing the likelihood or impact of harm.

Why it matters

An organization depends on trustworthy information and available services. A compromised account, altered record, or unavailable system can affect customers, operations, safety, and legal obligations. Security decisions should connect a technical weakness to the information or service at stake, likely harm, and safeguards that reduce it.

The CIA triad

Property	Meaning	Example
Confidentiality	Information is seen only by authorized parties.	Restrict payroll records to approved roles.
Integrity	Information remains accurate and changes are authorized.	Log and validate changes to a payment record.
Availability	Systems and information are usable when needed.	Maintain tested backups and redundant service capacity.

Controls often support more than one property. Encryption can protect confidentiality, while hashes and signed records can help detect unauthorized changes. Backups support availability, but do not alone ensure a service can be restored quickly.

```
Asset -> threat event -> vulnerability or exposure -> impact
                         ^                          |
                         |--- controls reduce -----|
Risk is assessed from likelihood and impact in context.
```

This is a simplified reasoning aid: controls can affect likelihood and impact, and real assessments consider dependencies and uncertainty.

Practical example

For an online appointment service, access control limits who can view patient data (confidentiality), audit trails record updates (integrity), and resilient hosting with recovery procedures helps keep booking available.

Common mistakes

- Treating the CIA properties as interchangeable. A control can improve one property while leaving another weak.
- Assuming encryption alone makes data secure. Key handling, access, endpoints, and recovery still matter.
- Equating a successful backup job with a tested recovery capability.

Identity and access

Authentication establishes which identity is requesting access. Authorization determines what that identity may do. Accounting or auditing records relevant actions.

Term	Question answered	Example
Authentication	Who are you?	Password plus a security key.
Authorization	What may you access or change?	A help-desk role can reset accounts but cannot export payroll.
Auditing	What happened, and by whom?	A record of a privileged configuration change.

Use least privilege: grant only the access needed for a defined task and review it when roles change. Common authentication factor classes are something known (such as a password), something possessed (such as a security key), and something inherent (such as a biometric). MFA combines different factor classes; two passwords are still one factor type. Authentication does not automatically grant permission to every resource.

Access control in practice

Access control decisions use an identity, a resource, and a policy. Role-based access control assigns permissions through job or service roles; attribute-based approaches can consider properties such as department, device state, or location. A file ACL, application role, or cloud policy can implement authorization. Review both direct grants and inherited group access.

Check	Example
Identity	Is this the employee's individual account, not a shared account?
Authentication	Was the sign-in verified with appropriate factors?
Authorization	Does the role allow viewing this record, or only updating it?
Accountability	Can the action be associated with a user and time in an audit record?

Security operations and monitoring

Security monitoring reviews events from endpoints, identity systems, networks, and applications to find activity that needs investigation. Logs provide records of events; a SIEM collects and correlates events to support searches, alerts, and investigations.

An alert is a signal to examine, not proof of an incident. Analysts validate context, preserve evidence, determine scope, and follow the organization's escalation process. Time synchronization, useful log fields, retention, and access controls affect whether records can support an investigation.

Practical example

A SIEM rule may flag repeated failed logins followed by a successful login from an unusual source. The analyst checks the account history, source details, endpoint activity, and user context before deciding whether to contain or escalate.

Common mistakes

- Treating every alert as a confirmed compromise.
- Ignoring false negatives, missing data sources, or incorrect time settings.
- Collecting logs without limiting access or retention to an approved policy.

Revision points

- Start with confidentiality, integrity, and availability; identify which property is at risk.
- Separate identity verification from permission decisions.
- A log is evidence of an event; a SIEM helps organize and correlate it; an alert still requires investigation.
- Apply least privilege, record important activity, and test recovery arrangements.

Revision exercises

- 1. A ransomware event encrypts shared files and delays a service. Identify the CIA properties affected and name one control relevant to each.
- 2. Explain why MFA and authorization solve different problems.
- 3. A SIEM reports failed logins followed by a success. List three sources of context to review before declaring an incident.
- 4. Draw the path from an asset through a threat and weakness to business impact. Show where controls can reduce likelihood or impact.

References

- Google Cybersecurity Certificate playlist
- Google course curriculum
- NIST Cybersecurity Framework

Networking Basics for Security

This is an introductory security reference, not CCNA course notes. It covers only the network concepts needed to reason about basic service exposure and communication.

How a connection is described

```
Application (for example, HTTP)
        | data
Transport (TCP or UDP; ports identify application endpoints)
        | segment/datagram
Internet (IP address and routing)
        | packet
Link (local Ethernet/Wi-Fi delivery; MAC address)
```

The layers are a useful model; real protocol stacks do not map perfectly to every simplified diagram. An IP address identifies a network-layer endpoint, while a MAC address is used for delivery on a local link. A router forwards IP packets between networks. DNS resolves names to records such as IP addresses; DNS itself does not prove that a destination is trustworthy.

Ports and protocols

A transport port helps distinguish services at an endpoint. TCP provides an ordered byte stream with connection setup and retransmission behavior. UDP sends independent datagrams without TCP's connection and delivery guarantees. Application protocols define the meaning of data carried over a transport.

Example service	Common registered port	Typical transport	Security use
DNS	53	UDP and TCP, depending on use	Name resolution; restrict and monitor resolvers appropriately.
SSH	22	TCP	Remote administration; restrict access and use strong authentication.
HTTP	80	TCP	Web traffic; plaintext HTTP is not confidential by itself.
HTTPS	443	TCP	HTTP protected with TLS in common deployments.

Port numbers are conventions and registrations, not proof of the application actually running. Services can use non-standard ports, and a registered port does not imply safe traffic. Check observed service behavior and policy, not only the number. See the IANA registry.

Practical example

A web server can be running locally and listening on TCP port 443, yet still be unreachable from a particular client because of routing or firewall policy. Conversely, an open port does not prove that the service is vulnerable. For an authorized local check, `ss -lnt` inspects listening TCP sockets; `ip address show` and `ip route show` inspect local interface and route state.

Common mistakes

- Treating a port number as a vulnerability or proof of a service identity.
- Equating "listening locally" with "reachable from the internet."

- Treating a failed ping as proof that a host or application is down; ICMP may be filtered.
- Assuming DNS resolution authenticates a site or validates the returned address.
- Confusing MAC addresses, IP addresses, hostnames, and ports.

Defensive applications

- Inventory expected listeners and compare them with approved service requirements.
- Restrict inbound traffic to necessary sources and ports.
- Use encrypted application protocols for sensitive data in transit and validate certificates.
- Correlate DNS, network, endpoint, and identity logs with synchronized timestamps.
- Test connectivity only within an authorized scope.

Revision exercises

- 1. Trace a browser request from hostname resolution through IP routing to a TCP service port.
- 2. Explain why a listener on port 443 may still be unreachable from another subnet.
- 3. Give two reasons an open port is not enough to conclude that a host is vulnerable.
- 4. Compare TCP and UDP at a high level and name one reason DNS may use either.

References

- Google Cybersecurity Certificate curriculum: Networks and Network Security
- IANA Service Name and Port Number Registry
- RFC 9293: Transmission Control Protocol
- RFC 768: User Datagram Protocol

Threats, Vulnerabilities, and Risk

Key terms

Term	Meaning	Example
Asset	Something valuable that needs protection.	Customer data, a service, or an employee account.
Threat	A circumstance or actor that could cause harm.	A phishing campaign targeting staff.
Vulnerability	A weakness that can be exploited or otherwise cause failure.	An unpatched internet-facing application.
Exploit	A method or code that takes advantage of a vulnerability.	A crafted request that triggers an application flaw.
Risk	The potential for loss, commonly assessed through likelihood and impact.	A reachable flaw could expose sensitive records.

Common weakness patterns

These are useful beginner categories; their presence alone does not establish exploitability or business risk.

Pattern	Example	Defensive response
Missing or delayed updates	An exposed application runs a version with a known flaw.	Inventory, prioritize, test, and deploy approved updates.

Pattern	Example	Defensive response
Weak identity protection	Reused credentials allow an attacker to enter an account.	MFA, unique credentials, rate limits, and sign-in monitoring.
Misconfiguration	A storage location is readable by unintended users.	Secure baselines, least privilege, and configuration review.
Excessive privilege	A routine account can administer unrelated systems.	Role review, just-in-time elevation, and audit logs.
Injection or input handling flaw	Untrusted input is interpreted as a command or query.	Safe APIs, validation, encoding, and security testing.
Unnecessary exposure	A service listens on an interface or port without a business need.	Remove or restrict the service and verify network policy.

Threat, vulnerability, and risk are related but not synonyms. A vulnerability may exist without a likely threat path; risk depends on context, exposure, impact, and existing safeguards.

Assessing a scenario

Use a repeatable sequence:

- 1. Identify the asset and the harm that matters.
- 2. Identify relevant threats and weaknesses.
- 3. Estimate likelihood and impact using the organization's method.
- 4. Consider existing controls and residual risk.
- 5. Record an owner, decision, and review date for treatment.

Example

An internet-facing service stores customer details. The service has a known unpatched weakness. The asset is customer information; the threat could exploit the exposed service; the weakness is the missing patch; potential impact includes unauthorized disclosure and service disruption. The team should validate exposure and business impact, apply the approved remediation, and verify the fix.

Common misconceptions

- A threat is not the same thing as a vulnerability: one can exploit the other.
- Risk is not a fixed property of a vulnerability; exposure and business impact change it.
- A high-severity score is an input to prioritization, not a complete business risk decision.
- "No known exploitation" does not prove that a weakness is harmless.

A short triage worksheet

Question	Record
What asset and owner are involved?	Name the system, data, and accountable owner.
What is the weakness and evidence?	Record version/configuration, finding, or observed behavior.
Is there a credible path to impact?	Note reachability, required access, and dependencies.
What is the likely harm?	Consider disclosure, alteration, outage, safety, or compliance.
Which controls already reduce exposure?	Confirm they are configured and operating.
What decision is needed?	Treatment, owner, due date, and verification step.

Revision points

- Trace the relationship: asset -> threat path -> weakness -> possible impact -> risk.

- Include current safeguards when estimating remaining risk.
- Record assumptions and revisit decisions as exposure or threat conditions change.

Revision exercises

- 1. For a public service with an overdue patch, name the asset, threat, vulnerability, and possible impact separately.
- 2. Why is a vulnerability scanner's severity score not a complete risk decision?
- 3. Give one preventive and one detective control that could reduce the impact of credential theft.
- 4. What evidence would you collect before deciding whether an exposed service is reachable?

References

- Google Cybersecurity Certificate playlist
- Google course curriculum
- NIST Cybersecurity Risk glossary
- NIST IR 8286 Rev. 1

Risk Management

Managing security risk

Risk management is the continuing process of identifying, assessing, treating, and reviewing risks in the context of organizational priorities. It helps teams decide where to spend limited time and resources and who is accountable for a decision.

Common treatment choices

Choice	Meaning	Example
Mitigate	Reduce likelihood or impact with safeguards.	Patch a service and restrict its network exposure.
Avoid	Stop the activity that creates the risk.	Retire an unsupported service.
Transfer/share	Allocate some financial or operational impact to another party.	Use an insurance policy while retaining security responsibilities.
Accept	Formally retain the risk within an approved tolerance.	Document a low-impact exception with an owner and expiry.

Risk transfer does not remove accountability or prevent harm. Acceptance should be an informed, authorized decision, not the result of an untracked omission.

Qualitative and quantitative assessment

Qualitative approaches use categories such as low, medium, and high. Quantitative approaches use numerical estimates. Either can be useful if the method, assumptions, and decision thresholds are understood. A precise-looking number is not automatically a precise estimate.

One simple teaching model is `risk = likelihood x impact`. It is not a universal calculation: organizations define their own scales, evidence requirements, risk appetite, and thresholds. A high-impact scenario can warrant attention even when likelihood is uncertain.

Example workflow

For a vulnerable server, establish which data and services it supports, whether it is exposed, the plausible threat path, business impact, and current safeguards. Prioritize remediation according to impact, exploitability, exposure, and service dependencies. Record the decision and validate the change after remediation.

Common mistakes

- Treating a risk register as a one-time inventory rather than a living record.
- Ranking solely by technical severity while ignoring reachability and business context.
- Recording a treatment without an owner, due date, or verification step.
- Assuming a vendor or insurer takes over all responsibility.

Revision points

- Assess risk in context and state assumptions.
- Choose and document a treatment, owner, and review point.
- Reassess after material changes to assets, exposure, controls, or threats.

Revision exercise

An internet-facing application stores customer data and has a known flaw. List the additional facts needed to estimate risk (for example, exploitability, authentication requirements, data sensitivity, compensating controls, and service dependencies). Recommend a treatment, owner, due date, and verification step. Do not assign a numerical score without a defined scale.

References

- Google Cybersecurity Certificate playlist
- Google course curriculum
- NIST Cybersecurity Risk glossary
- NIST IR 8286 Rev. 1

Security Controls

What a control does

A security control is a safeguard or process used to prevent, detect, or respond to unwanted events and reduce risk. Controls can be grouped by purpose or by how they are implemented.

Grouping	Types	Examples
By function	Preventive, detective, corrective	Access restrictions; monitoring alerts; restoring from a known-good backup.
By implementation	Technical, administrative, physical	MFA; an approved access policy; a locked server room.

A control's presence does not prove it works. Define its intended outcome, assign ownership, and check operation and coverage.

Control design questions

- 1. Which risk or requirement is the control intended to address?
- 2. What observable outcome shows that it is operating?
- 3. What systems, users, and data are in scope, and what is excluded?
- 4. How are exceptions approved, monitored, and expired?
- 5. How will the control be reviewed after a system or threat change?

Layered protection

Layering controls reduces reliance on one safeguard. For example, MFA can reduce account takeover risk, least-privilege authorization can limit what a compromised account can do, and logging can help detect suspicious activity. Each control has failure modes; together they can limit the chance or impact of harm.

Practical example

To protect an administrative account: require strong authentication, grant elevated permissions only when needed, log privileged actions, alert on unusual use, and maintain a tested recovery path. Review access when job duties change.

This is defense in depth: if prevention fails, detection and recovery can still reduce impact. Each layer needs an owner and a test. For example, a backup control is not established by a successful copy alone; a restore should be exercised against recovery objectives.

Common mistakes

- Assuming a policy alone enforces a control.
- Treating a tool purchase as evidence that risk is reduced.
- Applying a control without considering usability, exceptions, and bypass paths.
- Relying on one preventive measure without detection or recovery capability.

Revision points

- State the risk a control addresses and the result it should produce.
- Distinguish prevention, detection, and correction.
- Validate that the control is configured, operating, and reviewed.

Revision exercises

- 1. Classify MFA, an access-review policy, a locked server room, and a restore procedure by implementation type and function where applicable.
- 2. Choose one way to test whether a logging control is complete and useful.
- 3. Explain why purchasing a security product does not show that risk has been reduced.
- 4. For a shared administrator account, propose controls for prevention, detection, and recovery.

References

- Google Cybersecurity Certificate playlist
- Google course curriculum

Incident Response

Purpose

Incident response provides an organized way to handle suspected or confirmed security events. A consistent workflow helps limit harm, coordinate decisions, preserve useful evidence, restore services, and improve future readiness.

A practical workflow

Stage	Main activity	Example question
Prepare	Define roles, contacts, tools, escalation, and decision authority.	Who can isolate a production endpoint?
Detect and analyze	Validate signals, establish scope, and assess severity.	Is this login pattern expected, and which accounts are involved?

Stage	Main activity	Example question
Contain	Limit ongoing impact while preserving critical operations.	Can the affected host be isolated safely?
Eradicate	Remove the cause and unauthorized access.	Has the vulnerable service been fixed and persistence removed?
Recover	Restore services and monitor for recurrence.	Are systems clean, stable, and approved to return?
Learn	Record findings and improve controls and procedures.	Which detection or response step should change?

Organizations may name or combine these stages differently. Follow the approved incident plan and applicable reporting requirements.

Decision points

Decision	Information to establish
Is this an incident?	Validate the signal and apply the organization's incident criteria.
How severe is it?	Scope affected assets, data, accounts, service impact, and safety concerns.
What containment is safe?	Consider ongoing harm, business continuity, dependencies, and evidence preservation.
Who must be engaged?	Follow escalation roles, legal/privacy requirements, and communications plans.
Is recovery complete?	Confirm the cause is addressed, systems are monitored, and the owner approves return to service.

Evidence and communication

Keep a clear timeline, record actions and decision-makers, preserve relevant logs and artifacts according to policy, and restrict access to sensitive incident material. Coordinate communications through designated roles. Avoid changing affected systems before evidence needs and containment trade-offs have been considered.

Example

A SIEM alert shows a privileged account used from an unusual location. An analyst validates the event with identity and endpoint records, escalates under policy, and works with the system owner to contain access. The team determines scope, removes unauthorized access, restores normal operation, and documents follow-up actions.

Common mistakes

- Confusing an alert with a confirmed incident.
- Delaying escalation while waiting for certainty.
- Making undocumented changes that complicate investigation or recovery.
- Restoring systems before confirming the cause has been addressed.
- Closing the incident without recording lessons and owners for follow-up work.

Revision points

- Prepare before an incident: roles, authority, contacts, and evidence handling.
- Validate and scope before selecting containment actions.
- Track a timeline, communicate through assigned channels, and verify recovery.
- Use lessons learned to improve readiness and controls.

Revision exercises

- 1. A suspicious sign-in generates an alert. What should happen before deciding it is a confirmed incident?
- 2. Give an example where immediate containment could affect evidence or service availability.
- 3. Name four items to record in an incident timeline.
- 4. What evidence supports a decision to return a host to service?

References

- Google Cybersecurity Certificate playlist
- Google course curriculum
- NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations

Final Revision Checklist

Use this page to explain a security scenario out loud, then check the supporting topic notes for detail.

Core reasoning sequence

- 1. Name the asset and its owner.
- 2. State the security property at risk: confidentiality, integrity, availability, or more than one.
- 3. Separate the threat, vulnerability, exposure, and possible impact.
- 4. Describe likelihood and impact using the organization's method and assumptions.
- 5. Identify preventive, detective, and recovery controls; verify that they work.
- 6. Record the decision, owner, escalation path, and review point.

Identity and network checks

- Authentication verifies the identity; authorization limits permitted actions; audit records support accountability.
- MFA combines different factor classes. Least privilege limits the damage a compromised account can cause.
- A port number is a transport endpoint convention, not proof of service identity or vulnerability.
- Listening locally does not mean reachable remotely. Consider address, route, firewall, and application behavior.
- An alert is a lead for investigation, not confirmation of an incident.

Scenario prompt

A public web service stores customer data. An account signs in from an unusual location, and the host has an unneeded service listening. Explain what evidence you would gather, how you would scope the risk, what controls you would verify, who should make containment decisions, and how you would confirm recovery. Avoid assuming compromise from one signal alone.